CorpLink PHP Lab

Challenge 04 — Cookie Manipulation

PHP EXPLOITATION · XE107-M04 · CYBERIUM ARENA

Questions: 8 · Topic: Cookie Manipulation · Privilege Escalation

QUESTION 01 RECONNAISSANCE

Extract the lab zip using the password `infected` and start it by running `bash start.sh` inside the extracted folder. Open your browser and navigate to `http://localhost:8080`. What is the title shown on the Challenge 04 card?

HOW TO SOLVE

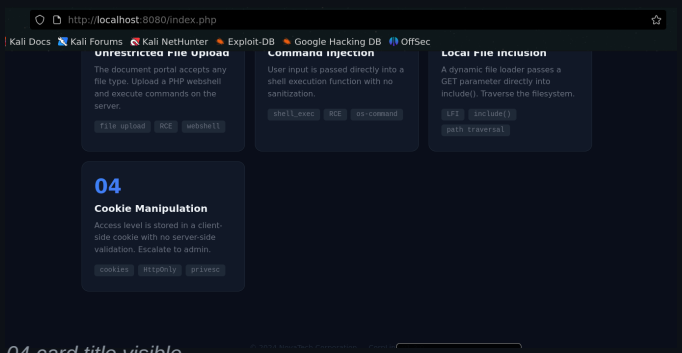
01 Extract the zip file using the password `infected`.

02 Navigate into the extracted folder and run `bash start.sh` to start the lab.

03 Open your browser and go to `http://localhost:8080`.

04 Find the Challenge 04 card on the overview page and read its title.

SCREENSHOTS



Lab overview page — Challenge 04 card title visible.

ANSWER

Cookie Manipulation

QUESTION 02 RECONNAISSANCE

Navigate to Challenge 04. The Staff Portal displays your current access role on the page. What role does the server assign to you by default?

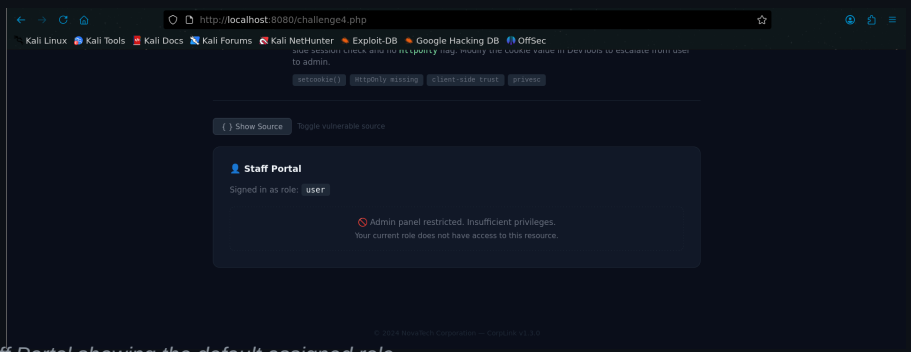
HOW TO SOLVE

01 Click on Challenge 04 in the navigation or on the overview card.

02 Look at the Staff Portal section on the page.

03 Read the role shown next to `Signed in as role`.

SCREENSHOTS



Challenge 04 — Staff Portal showing the default assigned role.

ANSWER

user

QUESTION 03 RECONNAISSANCE

Open DevTools (F12), go to the Storage tab, then Cookies → `http://localhost:8080`. What is the name of the cookie the server has set for your session?

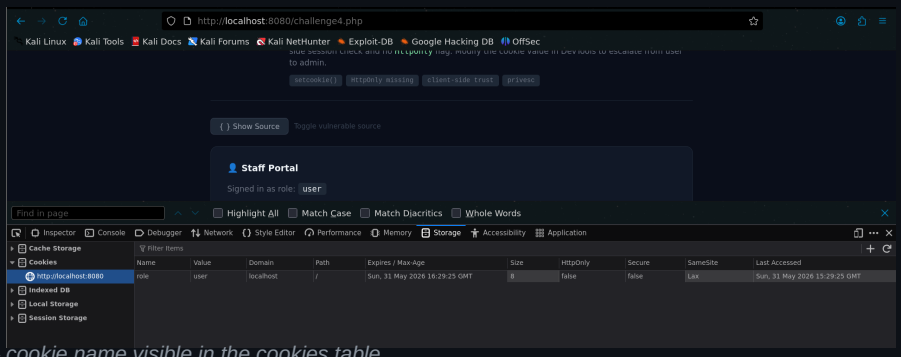
HOW TO SOLVE

01 Press F12 to open DevTools.

02 Go to the Storage tab and expand Cookies → `http://localhost:8080`.

03 Read the name of the cookie shown in the table.

SCREENSHOTS



DevTools Storage — cookie name visible in the cookies table.

ANSWER

role

QUESTION 04 SOURCE CODE ANALYSIS

Click the { } Show Source button on Challenge 04. What PHP function is used to create the cookie?

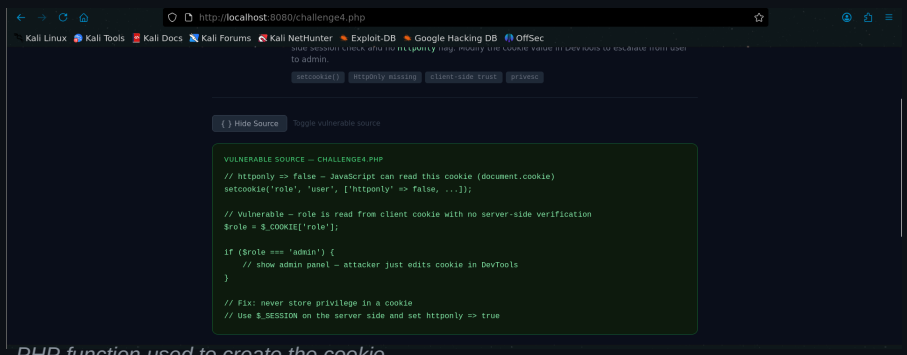
HOW TO SOLVE

01 Click the { } Show Source button at the top of Challenge 04.

02 Read the first line of the vulnerable source code.

03 Identify the PHP function used to set the cookie.

SCREENSHOTS



Source code panel — PHP function used to create the cookie.

ANSWER

setcookie

QUESTION 05 SOURCE CODE ANALYSIS

Read the source code. The server stores your role by reading it directly from the cookie your browser sends — no session, no server check. What PHP variable gives access to cookie values sent by the browser?

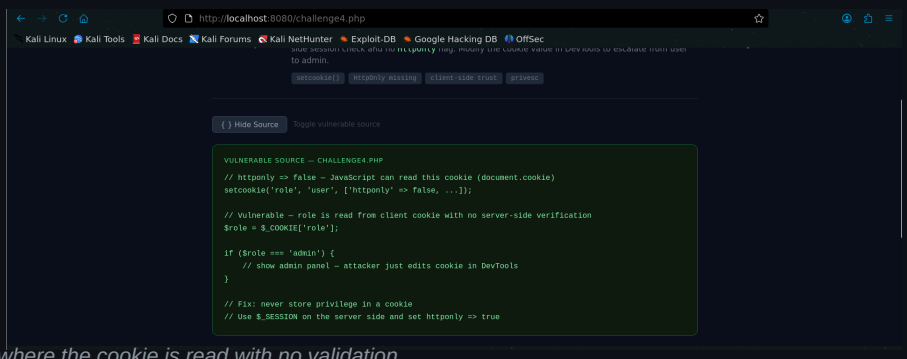
HOW TO SOLVE

01 The source code is still open from Q4.

02 Find the line where the role is read from the browser cookie.

03 Read the PHP variable used on the right side of that line.

SCREENSHOTS



Source code — line where the cookie is read with no validation.

ANSWER

$_COOKIE

QUESTION 06 EXPLOITATION

Go to DevTools → Storage → Cookies, change the value of the `role` cookie from `user` to `admin`, then refresh the page. What role is now shown next to `Signed in as role`?

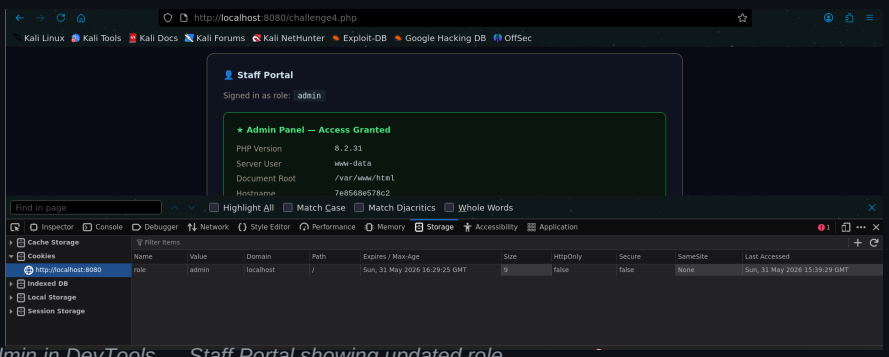
HOW TO SOLVE

01 Open DevTools (F12) → Storage → Cookies → `http://localhost:8080`.

02 Double-click the value of the `role` cookie and change it from `user` to `admin`.

03 Refresh the page and read the role shown in the Staff Portal.

SCREENSHOTS



Cookie changed to admin in DevTools — Staff Portal showing updated role.

ANSWER

admin

QUESTION 07 EXPLOITATION

With admin access unlocked, look at the information shown in the admin panel. What Linux user is the web server running as?

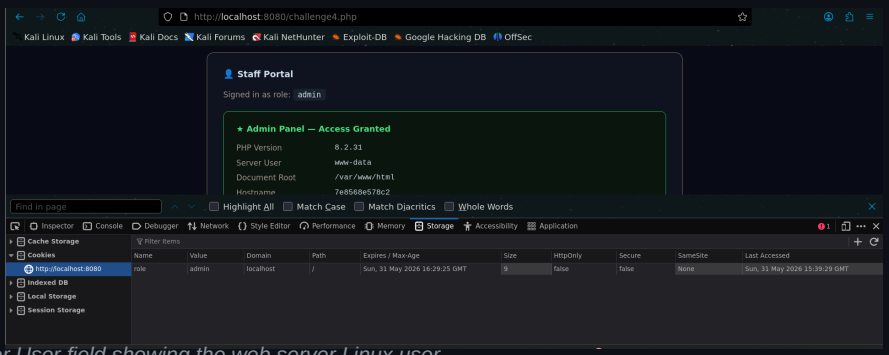
HOW TO SOLVE

01 The admin panel is now visible after the cookie change from Q6.

02 Find the `Server User` field in the admin panel.

03 Read the Linux username shown.

SCREENSHOTS



Admin panel — Server User field showing the web server Linux user.

ANSWER

www-data

QUESTION 08 MITIGATION

Click `{ } Show Source` and read the fix at the bottom. What should be used on the server side instead of a cookie to store the user's role securely?

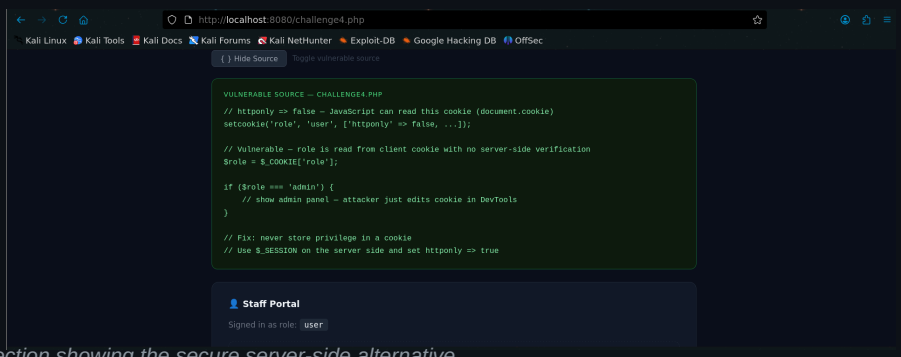
HOW TO SOLVE

01 Click `{ } Show Source` — the fix is shown in the comments at the bottom of the code.

02 Read the PHP built-in the fix recommends for secure server-side session handling.

03 Note that using this keeps the role on the server — the browser can never touch it.

SCREENSHOTS



Source code — fix section showing the secure server-side alternative.

ANSWER

$_SESSION